ISO/IEC 27701:2025

TABLA A.1 — CONTROLES PARA RESPONSABLES DE PII (PII CONTROLLERS)

Sección: Obligations to PII Principals (Obligaciones hacia los Titulares)

INFORME INTEGRAL DE IMPLEMENTACIÓN Y AUDITORÍA

Caso de Estudio: Universidad Nacional de San Agustín de Arequipa (UNSA)

DATOS DE LA ASIGNATURA Y AUDITORÍA:

- Institución Evaluada: Universidad Nacional de San Agustín de Arequipa (UNSA)
- Alcance Normativo: Controles A.1.3.2 al A.1.3.11 (Derechos ARCO, Información y DSAR)
- Marco Jurídico Peruano: Ley N° 29733, D.S. 016-2024-JUS, Ley N° 27444, Ley 30220
- Rol del Auditor: Ing. Rafael (MSc. Ciberseguridad & Auditoría TI, Lead Auditor ISO)
- Articulación Académica: Soporte Normativo y de Auditoría para el Proyecto TIF-DSAR

Arequipa, Perú — Semestre Académico 2026

Marco Normativo y Estructura de la Sección A.1.3

La sección A.1.3 de la norma ISO/IEC 27701:2025 ('Obligations to PII Principals') materializa el principio de soberanía y control del titular sobre sus datos personales. En la jurisdicción peruana, esta sección corresponde directamente al ejercicio y garantía de los Derechos ARCO (Acceso, Rectificación, Cancelación y Oposición) contemplados en la Ley N° 29733 y reforzados por el Decreto Supremo N° 016-2024-JUS.

Este informe aborda los 10 controles de la sección mediante un enfoque riguroso de 1 página por control, articulando la visión institucional de la UNSA (5W), el criterio técnico del auditor líder y el soporte al proyecto académico TIF-DSAR (Agente Inteligente de Atención de Solicitudes):

Control	Título Normativo (ISO 27701:2025)	Alcance Técnico y Legal	Ubicación
A.1.3.2	Determining/fulfilling obligations to principals	Obligaciones legales hacia titulares	Pág. 3
A.1.3.3	Determining information for PII principals	Definir información y timing de entrega	Pág. 4
A.1.3.4	Providing information to PII principals	Entrega clara y accesible de información	Pág. 5
A.1.3.5	Providing mechanism to modify/withdraw consent	Mecanismo para revocar consentimiento	Pág. 6
A.1.3.6	Providing mechanism to object to processing	Mecanismo de Derecho de Oposición	Pág. 7
A.1.3.7	Access, correction or erasure	Derechos ARCO (Acceso, Rectificación, Supresión)	Pág. 8
A.1.3.8	Obligations to inform third parties	Notificar cambios a terceros cesionarios	Pág. 9
A.1.3.9	Providing copy of PII processed	Entrega de copia de datos (Portabilidad)	Pág. 10
A.1.3.10	Handling requests	Gestión formal de solicitudes DSAR (Procedimiento)	Pág. 11
A.1.3.11	Automated decision making	Decisiones automatizadas y transparencia IA	Pág. 12

Control A.1.3.2 — Determining and fulfilling obligations to PII principals

« Determinar y cumplir obligaciones hacia los titulares de PII »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall determine and document its legal, regulatory and business obligations to PII principals related to the processing of their PII and provide the means to meet these obligations."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** La entidad debe tener una lista oficial y completa de TODOS los derechos de los titulares (alumnos, docentes, egresados) y debe asegurar el presupuesto, sistemas y personal para cumplirlos efectivamente.
• ***Analogía de la vida real:*** *Una aerolínea está obligada por ley a reembolsar pasajes cancelados y atender reclamos; no puede decir 'no sabía', debe fijar esas políticas en sus manuales y tener módulos de atención en el aeropuerto con personal capacitado.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA está obligada por la Ley 29733 y D.S. 016-2024-JUS. En su web menciona derechos ARCO pero no tiene una Directiva aprobada por Resolución Rectoral ni una ventanilla especializada con plazos regulados.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Título III), D.S. 016-2024-JUS, Ley 27444 (debido procedimiento administrativo) y Ley Universitaria 30220.*
• **WHEN (Cuándo):** Primeros 60 días del despliegue del PIMS. Revisión anual obligatoria o ante cambios normativos del MINJUSDH.
• **HOW (Cómo):** 1. Identificar obligaciones de la Ley 29733. 2. Redactar el Reglamento Institucional de Derechos del Titular. 3. Aprobarlo vía Resolución Rectoral. 4. Habilitar mesa de partes física y módulo SISUNSA.
• **WHO (Quién):** Asesoría Jurídica y Secretaría General (redacción), OTI (canales virtuales) y Rectorado (aprobación formal).
• **WHAT (Qué entregables):** 1. Reglamento Institucional de Derechos de los Titulares. 2. Resolución Rectoral. 3. Catálogo de obligaciones frente a la comunidad.
• **WHERE (Dónde se ubica):** Portal de Transparencia Estándar, web institucional, mesa de partes general y Secretaría General.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: MEDIO

• **Observaciones de Auditoría:** La universidad reconoce derechos en su web pero no provee los medios reales (means): si un alumno acude a Mesa de Partes a pedir supresión de datos, el personal no sabe qué trámite seguir.
• **Recomendaciones de Remediación:** Aprobar el Reglamento de Derechos de Titulares por Consejo Universitario y designar formalmente al Oficial de Protección de Datos (DPO).

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.2

• **Guión Como Universidad (UNSA):** *"Para el control A.1.3.2, la UNSA no solo debe saber que la Ley 29733 existe, sino poner los medios reales para cumplirla. Hoy los derechos se mencionan en la web pero no hay ventanilla especializada. Proponemos aprobar un Reglamento de Derechos por Resolución Rectoral y habilitar módulos en SISUNSA y mesas de partes."*
• **Guión Como Auditor (Ing. Rafael):** *"Como auditor líder, califico este punto como PARCIALMENTE IMPLEMENTADO (Riesgo MEDIO). La norma pide determinar obligaciones y proveer los medios (means). La UNSA cumple la teoría legal pero falla en la práctica: no hay personal asignado ni formularios específicos. Exijo institucionalizar la oficina en 60 días."*

Control A.1.3.3 — Determining information for PII principals

« Determinar la información a proporcionar a los titulares »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall determine and document the information to be provided to PII principals regarding the processing of their PII and the timing of such a provision."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Se debe definir de antemano QUÉ DATOS EXACTOS se informarán al usuario (identidad, fin, transferencias, retención) y EN QUÉ MOMENTO se entregarán (de forma previa o simultánea a la recolección).
• ***Analogía de la vida real:*** *Cuando compras un medicamento, la ley exige un prospecto obligatorio en la caja con dosis, contraindicaciones y vencimiento. El laboratorio definió con exactitud qué informar antes de imprimir la caja.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** Aplica a todos los puntos de recolección de la UNSA. Aunque tiene una política web, no ha determinado el paquete informativo obligatorio para cada punto ni el timing; en admisión no se informa sobre la conservación de notas.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 18 - Deber de Información), D.S. 016-2024-JUS y directivas de la ANPD sobre avisos informativos.*
• **WHEN (Cuándo):** En la fase de diseño de formularios (plazo 45 días). Entrega de información previa o simultánea a la recolección de datos.
• **HOW (Cómo):** Diseñar Estructura Informativa Multinivel: Nivel 1 (aviso corto con finalidad y QR en el formulario) + Nivel 2 (política detallada en la web).
• **WHO (Quién):** OTI (interfaces), Asesoría Jurídica (redacción legal) y Dirección de Comunicación e Imagen Institucional.
• **WHAT (Qué entregables):** 1. Estándar Informativo para Recolección de Datos. 2. Plantillas de Avisos Multinivel. 3. Matriz de Momento Informativo (Timing).
• **WHERE (Dónde se ubica):** Fichas de inscripción de admisión, formularios SISUNSA, carteles de videovigilancia y boletas de pago.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: MEDIO

• **Observaciones de Auditoría:** En becas de comedor y bolsas de trabajo se piden datos socioeconómicos íntimos sin informar previamente el tiempo de conservación ni si serán compartidos con SISFOH/MIDIS.
• **Recomendaciones de Remediación:** Homologar todos los formularios físicos y digitales de recolección con la estructura informativa de la Ley 29733 (Art. 18).

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.3

• **Guión Como Universidad (UNSA):** *"El control A.1.3.3 exige definir qué le informamos al estudiante y en qué momento. La Ley 29733 exige informar el responsable, los fines y las transferencias. Implementaremos avisos multinivel: un aviso corto con código QR en los formularios de matrícula y admisión, y la política completa en la web."*
• **Guión Como Auditor (Ing. Rafael):** *"Califico como PARCIALMENTE IMPLEMENTADO (Riesgo MEDIO). El control exige regular el timing: informar al momento exacto de la recolección. En la UNSA las políticas están en el pie de página de la web, pero el postulante o alumno no las ve al matricularse. Se exige la matriz informativa en 45 días."*

Control A.1.3.4 — Providing information to PII principals

« Proporcionar información a los titulares de PII »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall provide PII principals with clear and easily accessible information identifying the PII controller and describing the processing of their PII."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Exige la ENTREGA REAL Y ACCESIBLE de la información: debe estar en lenguaje claro (sin jerga legal abusiva), visible a simple vista y accesible sin costo ni barreras físicas o digitales.
• ***Analogía de la vida real:*** *Es como los letreros verdes de salida de emergencia en un cine: deben ser visibles a simple vista y entendibles por cualquiera, no guardados en un archivador cerrado de la gerencia.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA tiene política web, pero está en lenguaje legal complejo, no es accesible para discapacidades visuales y en los campus no existen carteles informativos de zona videovigilada conforme a la directiva de la ANPD.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Directiva de Seguridad de la ANPD para Videovigilancia, D.S. 016-2024-JUS y estándares W3C de accesibilidad web.*
• **WHEN (Cuándo):** Ejecución en 30 días calendario y actualización continua ante cambios de autoridades o sistemas informáticos.
• **HOW (Cómo):** 1. Rediseñar la sección web de privacidad con lenguaje ciudadano. 2. Instalar carteles físicos de videovigilancia en los 3 campus. 3. Poner banners en SISUNSA.
• **WHO (Quién):** Oficina de Comunicación e Imagen (redacción accesible), OTI (web) y Servicios Generales (cartelería física).
• **WHAT (Qué entregables):** 1. Portal Web Accesible de Privacidad. 2. Cartelería física de videovigilancia homologada. 3. Guía rápida ilustrada de derechos.
• **WHERE (Dónde se ubica):** Página principal (`unsa.edu.pe`), puertas y pabellones de Ingenierías, Sociales y Biomédicas, y aulas virtuales.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: MEDIO-ALTO

• **Observaciones de Auditoría:** Hay más de 100 cámaras de seguridad activas en los campus sin ningún cartel de advertencia de videovigilancia que identifique al responsable del banco de datos.
• **Recomendaciones de Remediación:** Instalar con carácter de urgencia la cartelería física homologada de videovigilancia y rediseñar la política web en lenguaje accesible.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.4

• **Guión Como Universidad (UNSA):** *"El control A.1.3.4 exige que la información sea fácil de encontrar y entender. Rediseñaremos la web de privacidad para que cualquier alumno la comprenda sin ser abogado. Además, colocaremos carteles visibles en los ingresos de los campus avisando sobre las cámaras de videovigilancia y quién custodia las grabaciones."*
• **Guión Como Auditor (Ing. Rafael):** *"Levanto una observación formal calificada como PARCIALMENTE IMPLEMENTADO (Riesgo MEDIO-ALTO). Omitir carteles de videovigilancia en los campus es una infracción pasible de sanción por la ANPD. Los estudiantes no tienen forma de saber quién custodia las grabaciones. Ordeno subsanar carteles en 30 días."*

Control A.1.3.5 — Providing mechanism to modify or withdraw consent

« Proporcionar mecanismo para modificar o revocar el consentimiento »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall provide a mechanism for PII principals to modify or withdraw their consent."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Dar consentimiento no es irreversible; el titular tiene derecho a cambiar de opinión. La entidad debe ofrecer un mecanismo tan fácil para RETIRAR el permiso como lo fue para otorgarlo.
• ***Analogía de la vida real:*** *Si te suscribes a un boletín o servicio web con un solo clic, debe haber un botón visible que diga 'Cancelar suscripción'. Sería abusivo e ilegal que para salirte te exijan enviar una carta notarial.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** Aplica para tratamientos basados en consentimiento (fotos institucionales, becas voluntarias, correos de eventos externos). La UNSA no dispone de ningún botón ni trámite en SISUNSA para desmarcar autorizaciones.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 13.5), D.S. 016-2024-JUS (regla de equivalencia de medios para revocatoria gratuita y accesible).*
• **WHEN (Cuándo):** Desarrollo en 60 días calendario y vigencia permanente dentro de la plataforma virtual del estudiante.
• **HOW (Cómo):** 1. Habilitar en SISUNSA la pestaña 'Mis Permisos de Privacidad'. 2. Configurar casillas toggles para autorizaciones opcionales. 3. Actualizar bases de datos al desactivar.
• **WHO (Quién):** OTI (desarrollo informático) y Asesoría Jurídica (reglas de negocio sobre tratamientos revocables vs. obligatorios de ley).
• **WHAT (Qué entregables):** 1. Módulo Web de Gestión de Consentimientos en SISUNSA. 2. Formulario de Revocatoria para mesa de partes. 3. Procedimiento de baja técnica.
• **WHERE (Dónde se ubica):** Configuración de perfil en SISUNSA y Mesa de Partes física de la universidad.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** No existe ningún mecanismo en los sistemas institucionales para retirar el consentimiento. Los egresados no tienen opción de opt-out en correos masivos de posgrado.
• **Recomendaciones de Remediación:** Implementar el módulo de preferencias de privacidad en SISUNSA y agregar enlace de desuscripción automática al pie de los correos institucionales.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.5

• **Guión Como Universidad (UNSA):** *"El control A.1.3.5 garantiza que el estudiante sea dueño de su decisión. Si autorizó el uso de su foto o recibir correos de ferias de empleo, puede cambiar de opinión. Agregaremos una pestaña en SISUNSA llamada 'Mis Permisos' para que con un clic desactive las autorizaciones voluntarias, tal como exige la ley peruana."*
• **Guión Como Auditor (Ing. Rafael):** *"Declaro NO IMPLEMENTADO con riesgo ALTO. La revocabilidad es un pilar de la Ley 29733 y la ISO 27701. Retener datos contra la voluntad del titular sin una obligación legal imperativa constituye infracción grave. Se exige el despliegue del módulo de revocatoria en 60 días."*

Control A.1.3.6 — Providing mechanism to object to PII processing

« Mecanismo para oponerse al tratamiento (Derecho de Oposición) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall provide a mechanism for PII principals to object to the processing of their PII."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Aunque la entidad tenga base legal para procesar datos, si el titular tiene un motivo fundado y legítimo de afectación personal (seguridad, acoso), puede exigir que dejen de usar sus datos para ese fin específico.
• ***Analogía de la vida real:*** *Si una empresa publica el directorio con teléfonos y direcciones de todos sus trabajadores, pero una empleada tiene una orden de restricción contra una expareja violenta, tiene derecho a oponerse para proteger su integridad.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** El Derecho de Oposición es fundamental (Art. 22 Ley 29733). Aplica si un estudiante solicita que no se publique su nombre en murales o listas de mérito por razones de seguridad. La UNSA no tiene protocolo formal para esto.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 22 - Derecho de Oposición), D.S. 016-2024-JUS (plazo perentorio de respuesta: 10 días hábiles).*
• **WHEN (Cuándo):** Aprobación en 60 días calendario; respuesta obligatoria en un máximo de 10 días hábiles desde la presentación.
• **HOW (Cómo):** 1. Diseñar el Procedimiento de Oposición. 2. Crear formulario físico y digital. 3. Ponderar legalmente el motivo del titular frente al deber institucional. 4. Bloquear el tratamiento en 10 días.
• **WHO (Quién):** Asesoría Jurídica (evaluación de motivos fundados), Secretaría General (recepción) y OTI (bloqueo en base de datos).
• **WHAT (Qué entregables):** 1. Directiva Institucional de Oposición. 2. Formulario Normalizado de Oposición de PII. 3. Matriz de criterios de ponderación legal.
• **WHERE (Dónde se ubica):** Mesa de partes física, mesa de partes virtual de la UNSA y módulo de trámites del estudiante.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** Se identificó la publicación de listas de notas con nombres y DNI completos en murales físicos de facultades, sin permitir a los estudiantes oponerse por privacidad o seguridad.
• **Recomendaciones de Remediación:** Prohibir la exhibición pública de DNI en listas de calificaciones y aprobar el procedimiento formal de oposición con plazo de 10 días.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.6

• **Guión Como Universidad (UNSA):** *"El control A.1.3.6 corresponde a la letra 'O' de los derechos ARCO: el Derecho de Oposición. Si un alumno tiene motivos justificados, como sufrir acoso o amenazas, puede oponerse a que su nombre se publique en murales. Crearemos el formulario oficial con un plazo legal de 10 días hábiles para resolver y bloquear los datos."*
• **Guión Como Auditor (Ing. Rafael):** *"Califico como NO IMPLEMENTADO (Riesgo ALTO). Denegar injustificadamente el derecho de oposición es sancionado con multas graves por la ANPD. En la UNSA los estudiantes no tienen una vía formal para oponerse a la difusión pública de sus datos. Exijo emitir la directiva y formulario en 60 días."*

Control A.1.3.7 — Access, correction or erasure

« Acceso, rectificación o supresión (Derechos ARCO) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall implement policies, procedures or mechanisms to meet its obligations to PII principals to access, correct or erase their PII."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Es el núcleo de los Derechos ARCO: Acceso (saber qué datos tienen de ti), Rectificación (corregir errores o desactualizaciones) y Cancelación/Supresión (borrar datos cuando no haya base legal o ya no sean necesarios).
• ***Analogía de la vida real:*** *Si en tu reporte crediticio o en tu DNI tu apellido está mal escrito o figura una deuda ya pagada, tienes derecho a que corrijan el error y borren el registro deudor. La entidad no puede negarse.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA tramita rectificaciones de nombres o notas mediante trámites administrativos tradicionales (FUT), pero son burocráticos y exceden los plazos legales (10 y 20 días). No existe protocolo de supresión de datos.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 19, 20 y 21), D.S. 016-2024-JUS (gratuidad absoluta de los derechos ARCO, plazos: 20 días acceso, 10 rectificación/cancelación).*
• **WHEN (Cuándo):** Aprobación en 60 días calendario. Cumplimiento estricto de plazos: 20 días para acceso y 10 para rectificación y supresión.
• **HOW (Cómo):** 1. Integrar trámite gratuito ARCO en el TUPA. 2. Habilitar módulo en SISUNSA con seguimiento. 3. Crear procedimiento técnico de borrado seguro y anonimización en OTI.
• **WHO (Quién):** Oficial de Protección de Datos (DPO), Secretaría General, OTI (ejecución técnica en bases de datos) y Asesoría Jurídica.
• **WHAT (Qué entregables):** 1. Procedimiento Operativo de Atención ARCO. 2. Formulario Único Gratuito ARCO. 3. Protocolo de Supresión y Anonimización Segura.
• **WHERE (Dónde se ubica):** Mesa de partes física de facultades, Mesa de Partes Virtual y módulo SISUNSA.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** Los trámites de rectificación de datos en Secretaría General demoran hasta 60 días, superando holgadamente los 10 días de ley. No existe proceso de supresión para postulantes no admitidos.
• **Recomendaciones de Remediación:** Rediseñar el flujo administrativo para cumplir estrictamente con los plazos de 10 y 20 días hábiles y eliminar tasas arancelarias en trámites de privacidad.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.7

• **Guión Como Universidad (UNSA):** *"El control A.1.3.7 representa el corazón de los Derechos ARCO: Acceso, Rectificación y Supresión. La ley peruana exige que sea 100% gratuito y rápido: 20 días para acceso y 10 para rectificar o borrar. Implementaremos el trámite digital en SISUNSA para que el alumno no tenga que hacer colas con papeles."*
• **Guión Como Auditor (Ing. Rafael):** *"Califico como PARCIALMENTE IMPLEMENTADO con riesgo ALTO. La debilidad crítica de la UNSA es la demora: los trámites burocráticos sobrepasan los plazos de ley, lo que expone a la universidad a multas de hasta 50 UIT por la ANPD. Exijo un sistema automatizado con alertas de vencimiento."*

Control A.1.3.8 — PII controllers' obligations to inform third parties

« Obligación de informar a terceros cesionarios »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall inform third parties with whom PII has been shared of any modification, withdrawal or objections pertaining to the shared PII, and implement appropriate policies, procedures or mechanisms to do so."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si compartiste datos con un tercero (SUNEDU, bancos, ministerios) y luego el titular rectifica o cancela su información, estás obligado a AVISARLE a ese tercero para que también actualice o borre los datos en sus sistemas.
• ***Analogía de la vida real:*** *Es el efecto dominó: si cambias legalmente de nombre en el RENIEC, no basta con actualizar su oficina; RENIEC avisa a SUNAT, Migraciones y bancos para que en todos lados figures con tu nombre correcto.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA comparte datos masivos con SUNEDU, MINEDU, bancos recaudadores y PRONABEC. Si un alumno corrige judicialmente su nombre o género en la UNSA, no existe procedimiento para notificar a esos terceros.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 16 y 20), D.S. 016-2024-JUS (obligación de comunicar rectificaciones a cesionarios en plazo breve).*
• **WHEN (Cuándo):** Diseño en 90 días calendario y ejecución en un máximo de 10 días hábiles tras aprobarse una rectificación o cancelación.
• **HOW (Cómo):** 1. Mantener registro de transferencias. 2. Diseñar Protocolo de Comunicación a Terceros. 3. Enviar oficios electrónicos o sincronización API hacia entidades externas.
• **WHO (Quién):** Dirección de Asuntos Académicos (DUFA), Secretaría General, OTI y Asesoría Jurídica.
• **WHAT (Qué entregables):** 1. Protocolo de Notificación a Terceros Receptores de Datos. 2. Registro de Transferencias y Notificaciones. 3. Modelo de Oficio de Comunicación ARCO.
• **WHERE (Dónde se ubica):** Secretaría General de la UNSA y módulos de interoperabilidad técnica de OTI.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: MEDIO

• **Observaciones de Auditoría:** Cuando un alumno rectifica apellidos por filiación, la UNSA actualiza su base interna pero no notifica a los bancos del padrón de matrícula, provocando rechazos de pago y desactualización externa.
• **Recomendaciones de Remediación:** Elaborar el protocolo de notificación a terceros y crear una bitácora de interoperabilidad de transferencias.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.8

• **Guión Como Universidad (UNSA):** *"El control A.1.3.8 evita que los datos errados queden flotando en otras entidades. Si la UNSA envió datos a SUNEDU o a bancos de cobranza, y el alumno corrige su nombre en la universidad, debemos notificar formalmente a esas instituciones externas. Implementaremos un protocolo de oficio digital automático."*
• **Guión Como Auditor (Ing. Rafael):** *"Determino este control como NO IMPLEMENTADO (Riesgo MEDIO). La cadena de exactitud de los datos se rompe si la UNSA no notifica a los terceros con quienes comparte información. Si un alumno corrige sus datos y no se avisa a SUNEDU, se producen perjuicios directos. Se exige el protocolo en 60 días."*

Control A.1.3.9 — Providing copy of PII processed

« Proporcionar copia de la PII tratada (Portabilidad / Acceso) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall be able to provide a copy of the PII that is processed, when requested by the PII principal."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si un usuario te dice 'quiero una copia de toda la información que tienes sobre mí', debes poder extraer y entregarle un reporte completo de sus datos en un formato legible, estructurado y seguro.
• ***Analogía de la vida real:*** *Es como pedir tu Historia Clínica completa en un hospital o el consolidado de movimientos bancarios: la institución está legalmente obligada a darte una copia íntegra de tu expediente.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA entrega certificados de notas y constancias de matrícula, pero cobra tasas (TUPA). No existe mecanismo para entregar gratuitamente una copia consolidada de datos médicos, biométricos o de biblioteca.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 19 - Derecho de Acceso y Gratuidad), D.S. 016-2024-JUS (entrega en formato accesible y legible).*
• **WHEN (Cuándo):** Desarrollo en 60 días calendario; entrega de la copia en un máximo de 20 días hábiles tras la solicitud formal.
• **HOW (Cómo):** 1. Crear en SISUNSA el botón 'Descargar mi Expediente de Datos Personales'. 2. Generar PDF/ZIP cifrado con datos académicos, médicos y registros. 3. Para solicitudes presenciales, entregar reporte impreso sin costo.
• **WHO (Quién):** OTI (scripts de extracción y compilación de datos) y Secretaría General (entrega presencial).
• **WHAT (Qué entregables):** 1. Módulo digital de auto-descarga de expediente de PII en SISUNSA. 2. Formato del Reporte Maestro de Datos Personales. 3. Protocolo de entrega segura.
• **WHERE (Dónde se ubica):** Menú del estudiante en SISUNSA y Mesa de Partes General de la UNSA.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: MEDIO

• **Observaciones de Auditoría:** La universidad condiciona la entrega de información personal al cobro de aranceles (ej. certificados), vulnerando la gratuidad del Derecho de Acceso de la Ley 29733. No hay forma de exportar registros biométricos.
• **Recomendaciones de Remediación:** Implementar la descarga gratuita del expediente de datos personales en SISUNSA y definir el protocolo para registros especiales de biometría e imágenes.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.9

• **Guión Como Universidad (UNSA):** *"El control A.1.3.9 exige que la universidad pueda entregarle al alumno una copia completa de toda su información. Hoy entregamos certificados pero cobrando tasas y solo de notas. Implementaremos una opción en SISUNSA para descargar gratis su Expediente de Privacidad en PDF con todos sus datos consolidados y cifrados."*
• **Guión Como Auditor (Ing. Rafael):** *"Evalúo este control como PARCIALMENTE IMPLEMENTADO (Riesgo MEDIO). Cobrar por copias de datos personales vulnera la gratuidad establecida por la ANPD. Además, la OTI debe poder exportar datos en formatos estructurados estándar. Recomiendo habilitar la función de exportación gratuita en 60 días."*

Control A.1.3.10 — Handling requests

« Gestión y resolución de solicitudes de titulares (DSAR) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall define and document policies and procedures for handling and responding to legitimate requests from PII principals."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Es el PROCEDIMIENTO OPERATIVO COMPLETO para atender solicitudes de derechos (DSAR): cómo se valida la identidad del titular, cómo se registra, quién investiga internamente, quién responde y cómo se cumplen los plazos.
• ***Analogía de la vida real:*** *Es como el Libro de Reclamaciones formal: no basta con tener el libro; la empresa tiene un manual estricto que dice que cada reclamo se numera, se deriva, se investiga y se responde por escrito en el plazo de ley.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO (Formalmente).**
• **Sustento técnico-legal:** Las solicitudes de datos en la UNSA entran por Mesa de Partes genérica bajo la Ley 27444 (plazo de 30 días), violando los plazos más cortos de la Ley 29733 (10 y 20 días). Este es el foco directo del proyecto TIF-DSAR.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Título III), D.S. 016-2024-JUS (plazos de 10 y 20 días hábiles) y Ley 27444 (principios de celeridad y eficacia).*
• **WHEN (Cuándo):** Primeros 60 días calendario para el procedimiento administrativo y tecnológico.
• **HOW (Cómo):** 1. Aprobar la Directiva de Procedimiento DSAR. 2. Implementar flujo digital con numeración de expediente de privacidad. 3. Incorporar el Agente de IA (TIF-DSAR) para preclasificar y redactar respuestas.
• **WHO (Quién):** Oficial de Protección de Datos (DPO), Secretaría General, Asesoría Jurídica y OTI.
• **WHAT (Qué entregables):** 1. Manual de Procedimientos DSAR de la UNSA. 2. Libro Digital de Registro de Solicitudes ARCO. 3. Modelos de resolución de respuesta formal.
• **WHERE (Dónde se ubica):** Sistema de Trámite Documentario (STD) de la UNSA y Mesa de Partes Virtual.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** La universidad carece de un procedimiento especial para solicitudes de datos personales. Las peticiones se mezclan con trámites generales, perdiendo trazabilidad y venciendo los plazos legales.
• **Recomendaciones de Remediación:** Separar el flujo de solicitudes de privacidad en el Sistema de Trámite Documentario y desplegar un sistema de seguimiento automatizado con semáforos de plazos.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.10

• **Guión Como Universidad (UNSA):** *"El control A.1.3.10 es el procedimiento operativo que hace realidad los derechos de los alumnos. Si un pedido entra por Mesa de Partes común, se pierde entre miles de papeles. Con este control creamos un flujo especializado: valida identidad, clasifica el pedido y activa un reloj de 10 o 20 días. Aquí se integra nuestro proyecto TIF con el agente de IA."*
• **Guión Como Auditor (Ing. Rafael):** *"Determino este control como NO IMPLEMENTADO (Riesgo ALTO). No contar con un procedimiento documentado para gestionar solicitudes DSAR expone a la universidad a multas coercitivas de la ANPD ante el primer reclamo no atendido. Dictamino implementar de inmediato el protocolo DSAR y su libro de control en 45 días."*

Control A.1.3.11 — Automated decision making

« Decisiones automatizadas y perfilamiento de titulares »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall identify obligations, including legal obligations, to the PII principals resulting from decisions made by the organization which are related to the PII principal based solely on automated processing of PII, and be able to demonstrate how it addresses these obligations."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si un algoritmo o sistema de Inteligencia Artificial toma una decisión que afecta la vida de una persona SIN intervención humana (rechazar una beca, asignar turnos o calificar), se debe explicar la lógica y garantizar el derecho a revisión humana.
• ***Analogía de la vida real:*** *Si postulas a un crédito bancario y una IA te rechaza en 2 segundos basándose en tu edad o código postal, tienes derecho a saber por qué fuiste rechazado y exigir que un analista humano revise tu caso manualmente.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA utiliza algoritmos para turnos de matrícula, selección de cupos de comedor universitario y calificación óptica de exámenes de admisión. No tiene un protocolo que reconozca el derecho a revisión humana de estas decisiones.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *ISO/IEC 27701:2025, Directivas de Inteligencia Artificial de la PCM y principios de debido procedimiento de la Ley 27444.*
• **WHEN (Cuándo):** Plazo de 60 días calendario para la auditoría de algoritmos y formalización del derecho de revisión humana.
• **HOW (Cómo):** 1. Inventariar sistemas de decisión automatizada. 2. Documentar la lógica de los algoritmos en fichas comprensibles. 3. Habilitar en SISUNSA el botón 'Solicitar revisión humana'. 4. Crear comités de apelación.
• **WHO (Quién):** OTI (documentación técnica de algoritmos), Asesoría Jurídica y Direcciones Académicas correspondientes.
• **WHAT (Qué entregables):** 1. Catálogo Institucional de Sistemas de Decisión Automatizada. 2. Protocolo de Garantía de Intervención Humana. 3. Fichas de Explicabilidad de Algoritmos.
• **WHERE (Dónde se ubica):** Reglamentos académicos de matrícula y becas, y en el sistema informático SISUNSA.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: MEDIO-ALTO

• **Observaciones de Auditoría:** Existen procesos donde el sistema informático rechaza beneficios estudiantiles de forma automatizada sin que los alumnos conozcan la fórmula exacta ni tengan derecho a una reconsideración manual.
• **Recomendaciones de Remediación:** Elaborar fichas de transparencia algorítmica y reglamentar formalmente el derecho a la revisión humana de decisiones automáticas.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.3.11

• **Guión Como Universidad (UNSA):** *"Finalizamos con el control A.1.3.11: Decisiones automatizadas. En la UNSA usamos sistemas automáticos para ordenar matrículas o asignar cupos de comedor. Este control exige que ningún estudiante quede desamparado ante una decisión de una computadora: la universidad debe explicar la fórmula y garantizar que un ser humano pueda revisar su caso."*
• **Guión Como Auditor (Ing. Rafael):** *"Dictamino este control como NO IMPLEMENTADO con riesgo MEDIO-ALTO. Con el avance de la inteligencia artificial, este control de la ISO 27701:2025 cobra una vigencia vital. La universidad no puede escudarse en 'así lo calculó el sistema' sin brindar explicabilidad ni derecho a revisión humana. Se exige transparentar la lógica en 60 días."*

Dictamen Global de Auditoría — Sección A.1.3 y Articulación TIF-DSAR

Tras la evaluación de los 10 controles de la Sección A.1.3 de la norma ISO/IEC 27701:2025 ('Obligaciones hacia los Titulares de PII') en la Universidad Nacional de San Agustín (UNSA), el auditor líder Ing. Rafael determina que la institución presenta una vulnerabilidad crítica en la atención de Derechos ARCO y gestión de solicitudes DSAR. No existen flujos especializados con alertas de tiempo ni protocolos para decisiones automatizadas.

Control	Nombre del Control (ISO 27701)	Estado de Madurez	Nivel Riesgo	Prioridad
A.1.3.2	Determining/fulfilling obligations	Parcialmente Implementado	MEDIO	Alta (P1)
A.1.3.3	Determining info for principals	Parcialmente Implementado	MEDIO	Media (P2)
A.1.3.4	Providing info to principals	Parcialmente Implementado	MEDIO-ALTO	Alta (P1)
A.1.3.5	Modify or withdraw consent	No Implementado	ALTO	Alta (P1)
A.1.3.6	Mechanism to object (Oposición)	No Implementado	ALTO	Alta (P1)
A.1.3.7	Access, correction or erasure (ARCO)	Parcialmente Implementado	ALTO	Urgente (P1)
A.1.3.8	Inform third parties of changes	No Implementado	MEDIO	Media (P2)
A.1.3.9	Providing copy of PII (Portabilidad)	Parcialmente Implementado	MEDIO	Media (P2)
A.1.3.10	Handling requests (DSAR)	No Implementado	ALTO	Urgente (P1)
A.1.3.11	Automated decision making	No Implementado	MEDIO-ALTO	Media (P2)

Articulación Estratégica con el Proyecto TIF-DSAR (Agente de IA):

Los controles evaluados justifican plenamente el Trabajo de Investigación Formativa (TIF-DSAR): El desarrollo de un Agente de Inteligencia Artificial especializado en atención de solicitudes automatiza de forma directa los controles A.1.3.6 (Oposición), A.1.3.7 (Acceso/Rectificación/Cancelación) y A.1.3.10 (Gestión de Solicitudes). El agente valida identidad, clasifica pedidos, controla plazos perentorios de 10 y 20 días hábiles y genera borradores técnicos de respuesta, mitigando el riesgo de sanciones administrativas ante la ANPD.

FIRMA Y RESPONSABILIDAD TÉCNICA DEL AUDITOR LÍDER:

Ing. Rafael — Especialista en Ciberseguridad y Auditoría TI (MSc.) | Lead Auditor ISO/IEC 27001 & 27701